

Mercado Livre · DFIR Platform

Digital Forensics and Incident Response Platform · IDOR Investigation Case

LangGraph · RAG · MCP-safe Tools · Human-in-the-loop · Dry-run

Scored IPs	IDOR Findings	Anomalous IPs	Agent Decisions
5726	182	172	4

Incident priority: P1 · Severity: critical · Dry-run: True

SOC Chat Investigation Human Approval Forensic Evidence RAG / MCP Logs

SOC Agent Chat

Olá. Sou o DFIR SOC Assistant. Posso responder sobre IPs atacantes, janela do ataque, IDOR, evidências, IOCs e recomendações de contenção.

Quais são os top IPs atacantes?

Resposta gerada pelo SOC Assistant com RAG local, artefatos forenses e MCP-safe tools em modo dry-run.

Evidências principais

- 204.210.158.207 · risk=86.04 · level=critical · requests=12409 · invoices=6481
- 73.130.229.200 · risk=85.88 · level=critical · requests=12453 · invoices=6441
- 216.21.168.27 · risk=85.76 · level=critical · requests=12429 · invoices=6405
- 74.88.210.56 · risk=85.73 · level=critical · requests=12426 · invoices=6426
- 24.163.83.34 · risk=84.96 · level=critical · requests=12244 · invoices=6376

Dry-run ativo. Nenhuma ação externa foi executada.

Qual foi a janela do ataque?

Resposta gerada pelo SOC Assistant com RAG local, artefatos forenses e MCP-safe tools em modo dry-run.

Evidência consultada

- total_attack_events: 96829
- first_seen: 2020-10-01 00:00:00.000000
- last_seen: 2020-12-31 23:58:00.000000
- unique_attack_ips: 20
- unique_invoices_accessed: 10221
- unique_tokens_seen: 35

Dry-run ativo. Nenhuma ação externa foi executada.

Pergunte algo: ex. Quais são os top IPs atacantes?

↑



Explique IDOR e Broken Access Control



Resposta gerada pelo SOC Assistant com RAG local, artefatos forenses e MCP-safe tools em modo dry-run.

Dry-run ativo. Nenhuma ação externa foi executada.

Ver payload técnico

```
{
  "question": "Explique IDOR e Broken Access Control"
  "answer":
    "Resposta gerada pelo SOC Assistant com RAG local, artefatos forenses e MCP-safe tools em modo dry-run."
  "rag_context": {
    "query": "Explique IDOR e Broken Access Control"
    "top_k": 3
    "retrieved_documents": [
      0: {
        "source":
          "C:\\Users\\mlsob\\Developer\\idor-response-platform\\data\\knowledge\\broken_access_control.md"
        "title": "broken_access_control"
        "score": 4
        "content_preview":
          "# Broken Access Control Notes\\n\\nBroken access control includes missing authorization checks, ID
          OR, privilege escalation, and improper object-level authorization.\\n\\nFor invoice endpoints, serv
          er-side ownership checks are mandatory.\\n\\nMitigation:\\n- Enforce object-level authorization.\\n-
          Avoid trusting client-provided identifiers.\\n- Monitor enumeration behavior.\\n- Add rate limitin
          g.\\n- Log denied access attempts."
      }
      1: {
        "source":
          "C:\\Users\\mlsob\\Developer\\idor-response-platform\\data\\knowledge\\idor_playbook.md"
        "title": "idor_playbook"
        "score": 2
        "content_preview":
          "# IDOR Investigation Playbook\\n\\nIDOR occurs when an application exposes a direct object referen
          ce and fails to verify whether the requester is authorized to access that object.\\n\\nRelevant sig
          nals:\\n- High unique object diversity per client\\n- Sequential object ID access\\n- High success r
          ate across unrelated object IDs\\n- Repeated access to invoice-like identifiers\\n- Automation patt
          erns such as stable user-agent and high request volume\\n\\nInvestigation steps:\\n1. Identify high-
          risk IPs.\\n2. Confirm invoice diversity.\\n3. Inspect sequential_access_ratio.\\n4. Compare with an
          omaly detection.\\n5. Review tokens and user-agents.\\n6. Recommend containment in dry-run first."
      }
    ]
  }
  "tool_result": NULL
  "safety": {
    "dry_run": true
    "external_actions_executed": false
    "mcp_mode": "safe_allowlisted_simulation"
  }
}
```